

Preparación del trabajo del auditor informático.

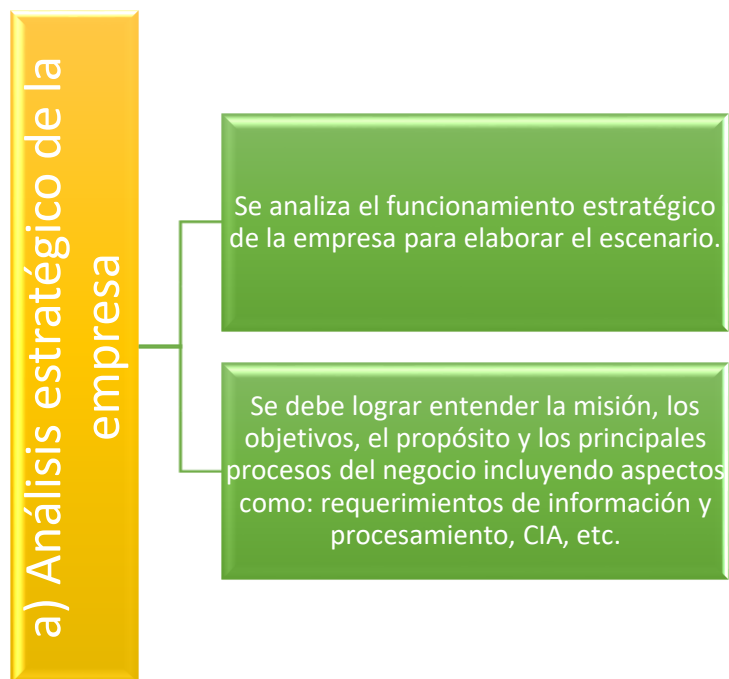
Concepto de análisis del riesgo informático

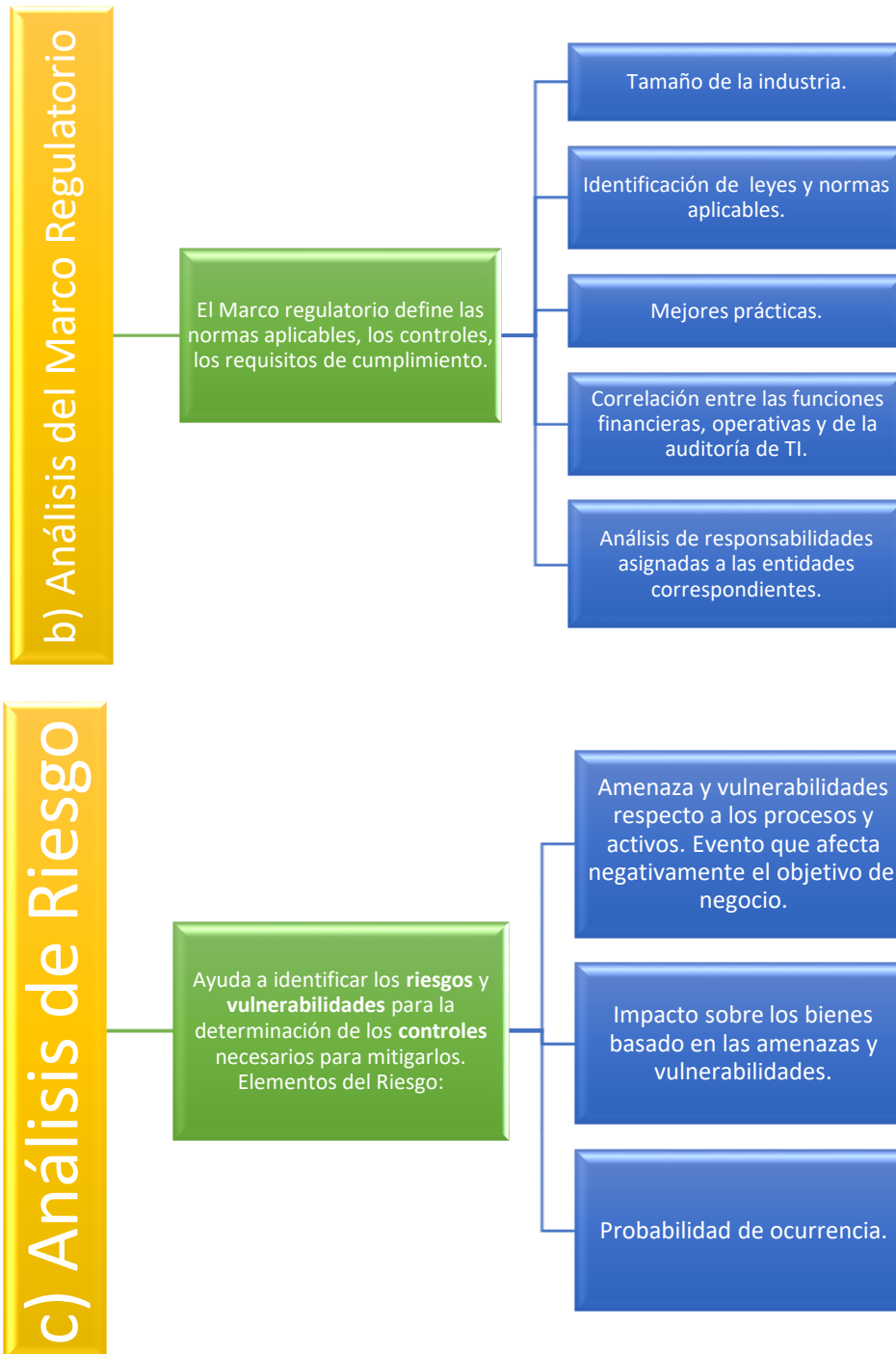
Según la Norma ISO 19011-2011, un plan de auditoría es una “descripción de las actividades y de los detalles acordados de una auditoría”. El trabajo del auditor está determinado por:

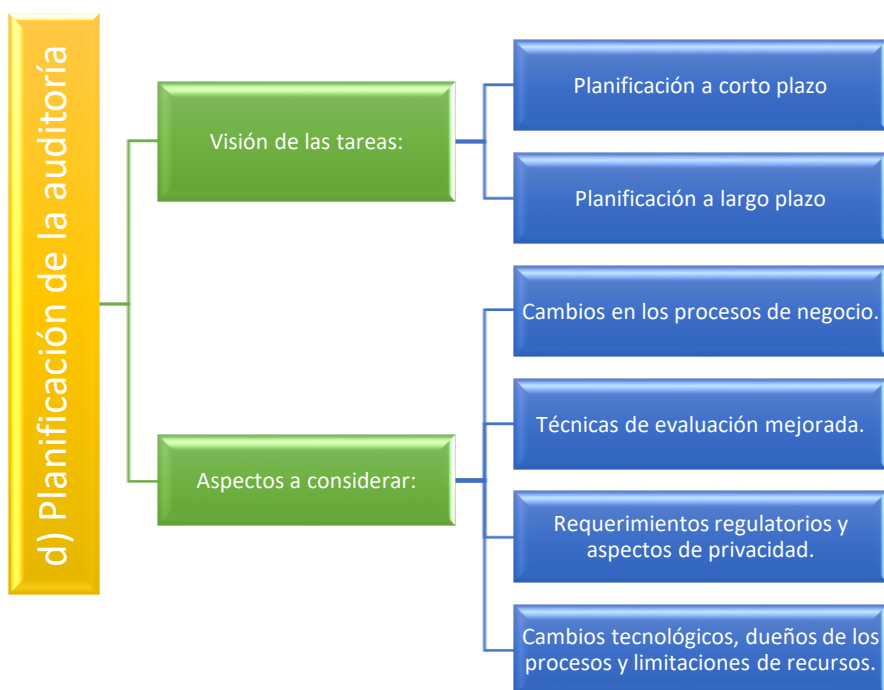
- a) Trabajar según un modelo de ciclos o períodos.
- b) Estructurar el plan por períodos de corto plazo (generalmente 1 año) y a largo plazo (generalmente de 5 años).
- c) Figurar, la misión y función, dentro del estatuto de la empresa.

El auditor informático tiene 3 principales tareas:

1) Entender el negocio y los procesos centrales de la empresa







2) Revisar el entorno de control interno

a) Métodos y procedimientos de revisión del entorno de control interno

Se desarrolla para suministrar con certeza razonable que se alcanzarán los objetivos del negocio y que los eventos adversos serán minimizados.

Aspectos claves del control:

- Determinar qué debería lograrse para alcanzar los objetivos del negocio.
- Determinar qué quiero evitar, detectar y corregir.

Los principales objetivos de los controles de TI son:

- El procesamiento seguro.
- La confidencialidad de la información.
- La integridad de la información.
- La disponibilidad de los datos.
- La gestión general de la función de TI en las organizaciones.



Seguridad de la
información

b) Tipos de controles internos

Los controles internos se dividen en 3 niveles:

1. Objetivos de control -> Se trata de la definición de objetivos de control que podrán ser aplicados tanto a aspectos manuales como automatizados.
2. Procedimientos de control -> El auditor arma los procedimientos planificados específicamente para esa auditoría.
3. Ejecución del control -> La ejecución del control en sí es el medio por el cual se logran los objetivos previamente establecidos.

c) Implementación de un sistema de control interno informático

Los controles pueden implantarse a varios niveles diferentes. La evaluación de los controles de las TIs exige analizar diversos elementos interdependientes. Por ello, es importante llegar a conocer bien la configuración del sistema, con el objeto de identificar los elementos, productos y herramientas que existen para saber dónde pueden implantarse los controles, así como para identificar posibles riesgos.

Para la implantación de un sistema de controles internos informáticos habrá que definir:

- Gestión de sistemas de información.
- Administración de sistemas.
- Seguridad.
- Gestión del cambio.

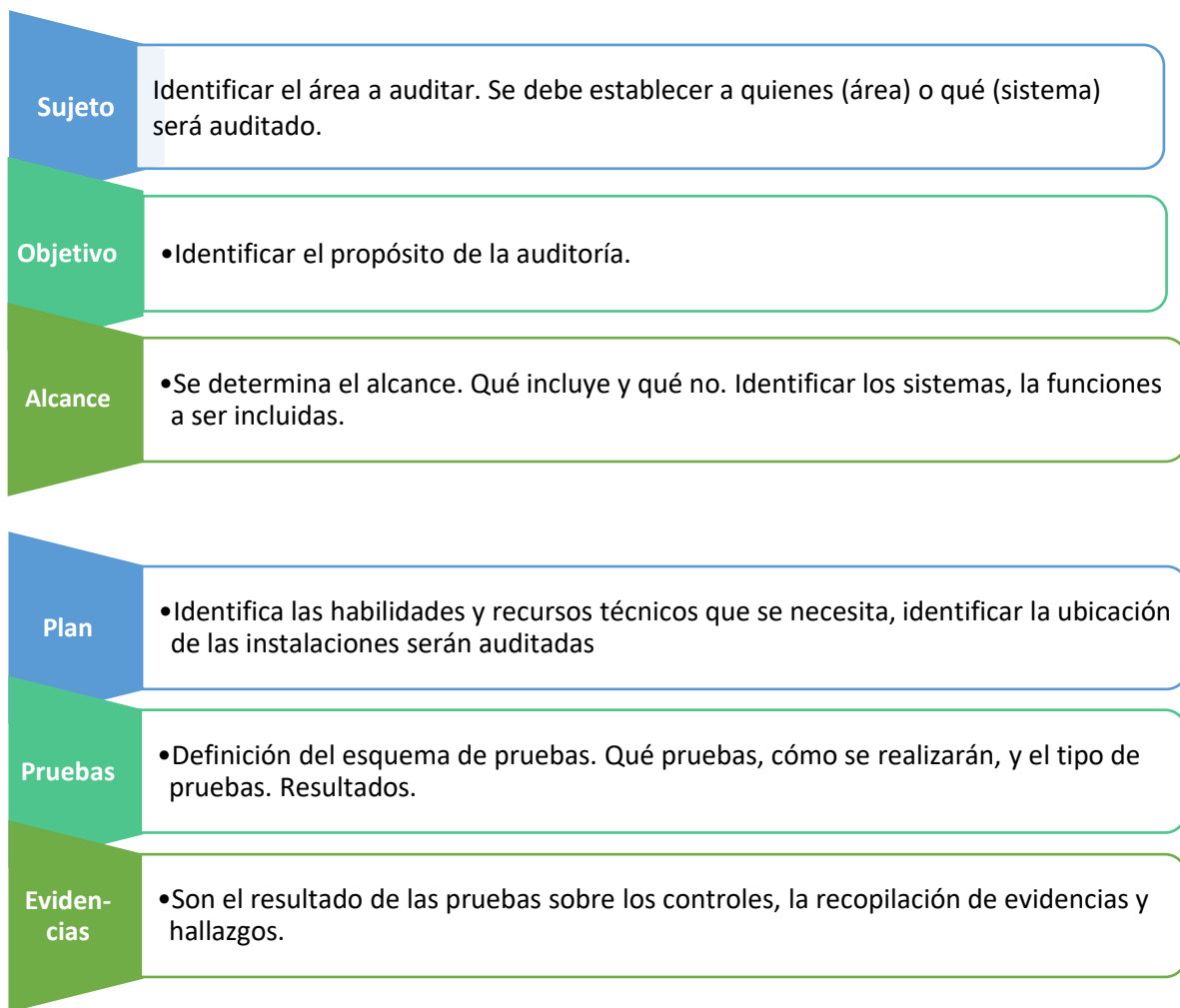
d) Herramientas de control

Son elementos de software que permiten definir uno o más elementos de control para cumplir una normativa y un objetivo de control. Las herramientas de controles más comunes son:

- Seguridad lógica del sistema.
- Seguridad lógica complementaria al sistema (desarrollado a medida).
- Seguridad lógica para entornos distribuidos.
- Control de acceso físico. Control de presencia.
- Control de copias.
- Gestión de soportes magnéticos.
- Gestión y control de impresión y envío de listados por red.
- Control de proyectos.
- Control de versiones.
- Control y gestión de incidencias.
- Control de cambios.

Todas estas herramientas están inmersas en controles nacidos de unos objetivos de control y que regulan la actuación de las distintas áreas involucradas.

3) Ejecutar una auditoría de sistemas de información o TI



Referencias bibliográficas

- IRAM / ISO 19011:20112 – Directrices para la auditoría de los sistemas de gestión.
- Piattini, M. y Del Peso, E. *Auditoría Informática: Un enfoque práctico* (Capítulo 2 “Control Interno y Auditoría Informática”; Capítulo 3 “Metodologías de Control Interno, Seguridad y Auditoría”; Capítulo 16 “Auditoría de la Calidad”).